

ISRA

Security Risk Assessment Tool

User Guide

A complete reference for security engineers and project managers using ISRA to conduct ISO 27005-compliant information security risk assessments.

Document type	User Guide
Version	1.0
Standard	ISO/IEC 27005 : 2022
Application	ISRA v2.0
Date	June 24, 2026

TABLE OF CONTENTS

1 Introduction

- 1.1 About ISRA
- 1.2 Key Concepts
- 1.3 ISO 27005 Alignment

2 Getting Started

- 2.1 System Requirements
- 2.2 Installation
- 2.3 First Launch & Login

3 Dashboard

- 3.1 Creating a New Assessment
- 3.2 Opening an Existing Assessment
- 3.3 Searching and Managing Projects

4 Assessment Workflow

- 4.1 Step 1 — Basic Info
- 4.2 Step 2 — Project Context
- 4.3 Step 3 — Business Assets
- 4.4 Step 4 — Supporting Assets
- 4.5 Step 5 — Vulnerabilities
- 4.6 Step 6 — Risk Scenarios
- 4.7 Step 7 — ISRA Report

5 AI-Assisted Suggestions

- 5.1 Enabling AI Features
- 5.2 Threat Suggestions
- 5.3 Vulnerability Suggestions

6 Risk Calculation Reference

- 6.1 Threat Factor Scoring
- 6.2 Likelihood Calculation
- 6.3 Impact Calculation
- 6.4 Inherent, Mitigated & Residual Risk

7 Exporting & Reporting

- 7.1 Risk CSV Export
- 7.2 Vulnerability CSV Export
- 7.3 Full Assessment JSON

8 Troubleshooting

9 Keyboard Shortcuts & Tips

1 INTRODUCTION

1.1 About ISRA

ISRA (Information Security Risk Assessment) is an Electron-based desktop application developed by Thales Group to help security engineers, project managers and evaluators conduct structured, repeatable security risk assessments aligned with the **ISO/IEC 27005 : 2022** standard. The tool guides users through a seven-step wizard that progressively builds a complete risk picture — from high-level project context down to individual threat scenarios, vulnerability chains, and mitigations.

ISRA runs entirely on-device. All assessment data is stored in an embedded H2 database on the local machine and never leaves the host system without an explicit export action. An optional Google Gemini AI integration provides intelligent threat and vulnerability suggestions to accelerate the assessment process.

1.2 Key Concepts

The following terms are used throughout this guide:

Business Asset	A primary piece of information or service with business value (e.g. Customer PII, Financial Records). Rated for Confidentiality, Integrity, Availability and Authenticity.
Supporting Asset	A technical component (server, API, database, network segment) that hosts or processes one or more Business Assets. Has a Security Level score.
Vulnerability	A weakness in a Supporting Asset that could be exploited. Scored 0–10 following the CVE/CVSS convention.
Risk Scenario	A specific combination of Threat Agent → Threat Verb → Supporting Asset → Business Asset, linked by one or more Attack Paths (vulnerability chains).
Attack Path	A sequence of vulnerabilities that, when chained together, allow a threat agent to reach a business asset.
Inherent Risk	The calculated risk level before any mitigations are applied.
Residual Risk	The remaining risk level after all accepted mitigations have been applied. This is the key output metric of the assessment.
Threat Factor	A composite score (Low / Medium / High / Very High) derived from attacker skill, reward motivation, resource access, group size, and detection difficulty.

1.3 ISO 27005 Alignment

ISO/IEC 27005 provides guidelines for information security risk management. ISRA maps directly to the standard's risk assessment phases:

ISO 27005 Phase	ISRA Module
-----------------	-------------

Context establishment	Basic Info + Project Context
Asset identification	Business Assets + Supporting Assets
Threat identification	Risk Scenarios (Threat Agent / Verb)
Vulnerability identification	Vulnerabilities tab
Risk estimation	Risk Scenarios (Likelihood + Impact calculation)
Risk evaluation & treatment	Risk Scenarios (Mitigation planning)
Risk communication	ISRA Report (export to CSV / JSON)

2 GETTING STARTED

2.1 System Requirements

Component	Minimum	Recommended
Operating System	Windows 10 / macOS 11 / Ubuntu 20.04+	Windows 11 / macOS 14 / Ubuntu 22.04
RAM	4 GB	8 GB+
Disk Space	500 MB free	2 GB free (for database growth)
Java (for dev)	OpenJDK 17	OpenJDK 21
Node.js (for dev)	18.x	20.x LTS
Internet (AI)	Not required	Required for AI suggestions

2.2 Installation

End-User Installation (packaged installer)

1	Download installer	Obtain the platform installer from your IT team: .exe for Windows, .dmg for macOS, or .ApplImage / .deb for Linux.
2	Run installer	Double-click the installer and follow the on-screen wizard. No pre-installed Java or Node.js is required — they are bundled.
3	Launch ISRA	Start ISRA from your Applications menu or desktop shortcut. A splash screen appears briefly while the embedded backend initialises.

Developer Setup

For developers who need to run ISRA from source:

1	Clone the repository	<code>git clone https://github.com/Rush-me/security-assessment-tool.git</code>
2	Install Electron dependencies	<code>cd isra/electron && npm install</code>
3	Install Angular dependencies	<code>cd isra/frontend && npm install</code>
4	Build the Spring Boot JAR	<code>cd isra/backend && mvn clean package -DskipTests</code>
5	Start Angular dev server	<code>cd isra/frontend && ng serve --port 4200</code>
6	Launch Electron (new terminal)	<code>cd isra/electron && npm run electron:dev</code>

- ✓ AI suggestions require a Google Gemini API key. Export `ISRA_AI_API_KEY=<your-key>` before launching. Without it, the app runs in full manual mode — this is expected and not an error.

2.3 First Launch & Login

On first launch you will see the ISRA login screen. If your organisation has pre-provisioned an account, enter your credentials. Otherwise:

1	Navigate to Register	Click the "Create account" link below the login form.
2	Enter username & email	Choose a username (used as your display initials) and a valid e-mail address.
3	Set a password	Choose a strong password. ISRA enforces minimum complexity rules.
4	Log in	Return to the login screen and sign in. You are redirected to the Dashboard.

- ! All data is stored locally on your machine. There is no central server or cloud sync. Logging out does not delete your assessments.

3 DASHBOARD

The Dashboard is the landing page after login. It lists all security assessments you have created, shows key metrics per project, and provides quick actions.

3.1 Creating a New Assessment

1	Click "New Assessment"	The blue button in the top-right corner of the Dashboard header opens the "Create Assessment" dialog.
2	Enter project name	Provide a unique, descriptive name (e.g. "SecurePay Gateway v2.1").
3	Click Create	ISRA creates the project and immediately opens it at the Basic Info step.

3.2 Opening an Existing Assessment

Click any project card on the Dashboard. The card displays summary statistics: risk count, high/critical count, average residual risk score, and the number of items pending mitigation. Clicking the card opens the project at the last-visited step.

3.3 Searching and Managing Projects

- Use the **search box** in the Dashboard header to filter assessments by name.
- Click the **user avatar** in the top-right corner to access your profile, settings, and the sign-out option.
- Use the **light/dark mode toggle** (sun/moon icon) to switch the application theme.

■ Projects cannot be permanently deleted from the Dashboard in the current release. Contact your administrator if you need to archive or remove a project.

4 ASSESSMENT WORKFLOW

After opening a project you are placed inside the Project Layout, which provides a left-hand navigation sidebar with all seven assessment steps. Each step must be completed before the subsequent step can produce meaningful results — although ISRA does not enforce a strict linear lock.

4.1 Step 1 — Basic Info

Basic Info captures the project identification metadata that appears on every report header. All four fields are mandatory.

Field / Control	Description	Required
Project Name	Human-readable name for the system being assessed.	Required
Version	Version or iteration number (e.g. 2.1, Sprint 4).	Required
Organization	Business unit or department responsible for the system.	Required
Classification	Data classification level. Options: Public, Internal, Confidential, Secret.	Required

- If any required field is left blank and you attempt to navigate away, ISRA displays a red validation banner at the top of the form. All required fields must be filled before the data is saved.

4.2 Step 2 — Project Context

Project Context describes the scope and environment of the assessment. It is the narrative foundation that informs all subsequent risk decisions.

Field / Control	Description	Required
Project Description	Free-text description of the system's purpose, architecture and scope. Rich formatting is supported.	Required
Reference URL	Link to a Confluence page, design doc, or architecture diagram.	Optional
Upload Document	Attach a PDF, Word doc, or image as supporting context. File is stored alongside the project.	Optional
Security Officer	Name of the person responsible for security decisions.	Optional
Security Evaluator	Name of the assessor conducting this review.	Optional
Security Assumptions	List of assumptions that were made (e.g. "Network is trusted", "Users are authenticated").	Optional
Security Requirements	Compliance or contractual security requirements that apply to this project.	Optional

- ✓ Click the "About this data" button (info icon) in any step to open the contextual help drawer, which explains the fields in detail.

4.3 Step 3 — Business Assets

Business Assets represent the primary information or services with business value that the system handles. At least one Business Asset is required to proceed.

Adding a Business Asset

1	Click "Add Asset"	The asset creation card expands inline above the asset table.
2	Enter Asset Name	Use a descriptive name that clearly identifies what is protected (e.g. "Cardholder Data (PAN)", "Authentication Tokens").
3	Select Asset Type	Choose from the dropdown: Data, Service, Process, or System.
4	Enter Description	Describe the purpose, scope, and why this asset is critical.
5	Set Security Property Ratings	Rate each of the four CIA+A properties (Confidentiality, Integrity, Availability, Authenticity) from None to High. Click a cell in the properties table to cycle through values.
6	Save	Click "Save Asset". The asset appears in the asset register table.

Security Property Rating Scale

Rating	Numeric Value	Meaning
None	0	This property is not applicable to the asset
Low	1	Loss would have minimal business impact
Moderate	2	Loss would have a significant but recoverable impact
High	3	Loss would have a critical or unrecoverable business impact

4.4 Step 4 — Supporting Assets

Supporting Assets are the technical components that host, process, or transmit Business Assets. They form the bridge between business value and technical attack surface.

Field / Control	Description	Required
HLD ID	Optional reference to a High-Level Design document identifier (e.g. SA.01, AWS-EC2-001).	Optional
Asset Name	Name of the technical component (e.g. "Payment API Gateway", "PostgreSQL Database").	Required

Asset Type	Category: Application, Database, Network, Infrastructure, Physical, or Service.	Optional
Description	Technical description including deployment context.	Optional
Security Level	Integer score 0–10 representing the asset's existing security posture (10 = fully hardened).	Optional
Business Assets	Multi-select list of Business Assets hosted by this component. Must be selected from assets already defined in Step 3.	Optional

- A Supporting Asset that is not linked to any Business Asset will not appear in the Risk Scenario dropdowns. Always link Supporting Assets to at least one Business Asset.

4.5 Step 5 — Vulnerabilities

Vulnerabilities represent exploitable weaknesses in Supporting Assets. They are later chained together as Attack Paths within Risk Scenarios.

Adding a Vulnerability

1	Click "Add Vulnerability"	The vulnerability creation panel opens on the right.
2	Enter Vulnerability Name	Use a precise name (e.g. "SQL Injection in login endpoint", "Default admin credentials on management portal").
3	Enter CVE Score	Provide the CVSS Base Score (0.0 – 10.0). Use 0 if no CVE exists and provide an internal score based on exploitability.
4	Set Tracking ID & URI	Enter your internal ticket ID (e.g. JIRA-1234) and a link to the tracking record for traceability.
5	Link to Supporting Assets	Select which Supporting Assets this vulnerability affects.
6	Save	Click "Save". The vulnerability appears in the Vulnerability Register sidebar.

Vulnerability Severity Levels

CVE Score Range	Severity Label	Typical Action
9.0 – 10.0	Critical	Emergency patching required
7.0 – 8.9	High	Fix in current release
4.0 – 6.9	Medium	Plan fix in next sprint
0.1 – 3.9	Low	Monitor and schedule fix
0.0	None	Informational; no active exploit path

4.6 Step 6 — Risk Scenarios

Risk Scenarios are the core analytical output of ISRA. Each scenario models one specific way in which a threat agent could exploit the system to harm a Business Asset. The two-panel layout shows the Risk Register (sidebar) on the left and the full Risk Editor on the right.

Creating a Risk Scenario

1	Click "Add Risk Scenario"	A new risk entry (R-01, R-02, ...) is created and immediately opened in the editor.
2	Define Threat Agent	Select or type the actor initiating the attack (e.g. External Attacker, Malicious Insider, Nation-State, Script Kiddie).
3	Define Threat Verb	Describe what the attacker does (e.g. "exfiltrates", "corrupts", "disrupts", "intercepts").
4	Select Target Assets	Pick the Business Asset and Supporting Asset that are targeted.
5	Set Threat Factor Attributes	Rate the attacker profile across five dimensions (see Section 6.1).
6	Set Occurrence	Estimate how often this threat vector has been observed (1–9 scale).
7	Add Attack Paths	Each Attack Path chains one or more Vulnerabilities. Click "Add Attack Path" and select vulnerabilities from those defined in Step 5.
8	Add Mitigations	Document planned or existing countermeasures. For each, specify a description, the benefit (0–100%), cost estimate, and management decision (Accept / Reduce / Transfer / Avoid).
9	Review Calculated Scores	ISRA automatically calculates Inherent, Mitigated, and Residual Risk scores in real time as you fill in the form.

Risk Register Sidebar

The left panel lists all risks with colour-coded badges. Click any risk entry to load it in the editor. Use the trash icon to delete a risk scenario.

- **Residual Risk badge:** Green (Low), Amber (Medium), Red (High), Deep Red (Critical).
- **Decision badge:** Reflect the current management decision for the risk.

Management Decision Options

Decision	Meaning
Accept	Acknowledge and accept the risk with no further action.
Reduce	Apply mitigations to lower the residual risk level.
Transfer	Transfer risk to a third party (e.g. insurance, outsourcing).
Avoid	Eliminate the risk by changing system design or removing functionality.

4.7 Step 7 — ISRA Report

The Report tab aggregates all assessment data into a summary view with KPI cards, visualisations, and tabular data. It is the primary deliverable for stakeholders.

KPI Cards

- **Total Risks:** Total count of risk scenarios in the assessment.
- **High / Critical:** Count of residual risks rated High or Critical.
- **Avg. Residual:** Average residual risk score across all scenarios (0–1 scale).
- **To Mitigate:** Count of risks with a "Reduce" decision still awaiting treatment.

Export Options

Click the "Export" button to access the following formats:

- **Risks CSV:** Tabular export of all risk scenarios with scores.
- **Vulnerabilities CSV:** Tabular export of all vulnerabilities.
- **Full Assessment JSON:** Complete structured data export for archiving or importing into other tools.

5 AI-ASSISTED SUGGESTIONS

ISRA integrates with Google Gemini to provide context-aware threat and vulnerability suggestions that accelerate the assessment process. AI features are entirely optional and can be used selectively.

5.1 Enabling AI Features

1	Obtain a Gemini API key	Visit the Google AI Studio (https://aistudio.google.com) and generate an API key.
2	Set the environment variable	Before launching: export ISRA_AI_API_KEY=AlzaSy...your-key-here
3	Verify the AI badge	In the Risk Scenarios editor header, look for the AI status indicator. "AI Available" (green dot) confirms the feature is active.

AI Status Indicators

Badge	Meaning
■ AI Available	API key is configured and Gemini is reachable.
■ Offline	API key is set but there is no internet connection.
■ Not Configured	No API key has been provided. Manual mode only.

5.2 Threat Suggestions

When editing a Risk Scenario, if at least one of Business Asset or Supporting Asset has been selected, the "AI Suggest Threats" button becomes active.

1	Select assets	Ensure the Business Asset and/or Supporting Asset fields are populated in the risk scenario form.
2	Click "AI Suggest Threats"	ISRA sends the asset context to Gemini and receives a list of threat suggestions.
3	Review suggestions	A panel displays suggested Threat Agent / Threat Verb pairs with explanations.
4	Apply a suggestion	Click any suggestion to auto-populate the threat fields. You can then edit the values manually before saving.

- AI suggestions are starting points, not authoritative outputs. Always review and validate each suggestion in the context of your specific system and threat model.

5.3 Vulnerability Suggestions

Similarly, in the Vulnerabilities tab, ISRA can suggest known vulnerabilities relevant to the selected Supporting Asset type. Click "AI Suggest Vulnerabilities" and review the suggested CVE IDs, scores, and descriptions. Apply any relevant suggestions and adjust the details to match your specific environment.

6 RISK CALCULATION REFERENCE

ISRA calculates risk automatically using a multi-factor model. Understanding the calculation helps you provide accurate inputs and interpret results correctly.

6.1 Threat Factor Scoring

The Threat Factor is a composite score derived from five attacker profile attributes, each rated on a 1–9 scale:

Attribute	Low (1–3)	Medium (4–5)	High (6–7)	Very High (8–9)
Skill Level	No technical skills	Some programming	Advanced hacking	Nation-state level
Reward Motivation	Low gain	Moderate financial	High financial/data	Strategic/political
Resource Access	No special access	Some insider access	Admin-level access	Full system access
Group Size	Individual	Small group	Organised group	State / organised crime
Intrusion Detection	High detection risk	Moderate risk	Low detection risk	Virtually undetectable

Formula: Threat Factor Score = Average of all provided attribute scores.

Threshold mapping: Score < 3.0 → Low | 3.0–5.0 → Medium | 5.0–7.0 → High | > 7.0 → Very High

6.2 Likelihood Calculation

Risk Likelihood combines the threat profile with how often the attack vector occurs:

- **Occurrence:** A 1–9 integer representing observed or estimated attack frequency.
- **Occurrence Level:** Same threshold mapping as Threat Factor (Low / Medium / High / Very High).
- **Incident Likelihood:** Computed from the combination of Threat Factor Level and Occurrence Level using a likelihood matrix.

6.3 Impact Calculation

Risk Impact is derived from the Business Asset's security property ratings (C, I, A, Au) and the Supporting Asset's Security Level score. The impact dimensions are:

- **Confidentiality Impact:** How much the loss of confidentiality of the target business asset affects the organisation.
- **Integrity Impact:** Impact of data corruption or unauthorised modification.
- **Availability Impact:** Impact of service disruption.
- **Authenticity Impact:** Impact of identity spoofing or non-repudiation failures.

ISRA takes the maximum impact value across all applicable dimensions to produce the overall Risk Impact score.

6.4 Inherent, Mitigated & Residual Risk

Three risk scores are computed for each scenario:

Score	Definition	Inputs
Inherent Risk	Risk level before any mitigations.	Threat Factor × Occurrence × Impact (via Attack Paths)
Mitigated Risk	Projected risk level if all planned mitigations are applied.	Inherent Risk reduced by the cumulative Benefit of each mitigation
Residual Risk	Actual remaining risk after accepted mitigations.	Inherent Risk reduced only by mitigations with decision = Reduce

Residual Risk Level Classification

Level	Score Range	Color Code	Recommended Action
Critical	0.75 – 1.0	Deep Red	Immediate remediation required
High	0.50 – 0.74	Red	Address within current sprint
Medium	0.25 – 0.49	Amber	Plan mitigation in next release
Low	0.00 – 0.24	Green	Monitor; accept or defer

7 EXPORTING & REPORTING

ISRA provides three export formats from the Report tab. Click the "Export" button and select the desired format from the dropdown menu.

7.1 Risk CSV Export

Produces a comma-separated file containing one row per Risk Scenario. Columns include: Risk ID, Risk Name, Threat Agent, Threat Verb, Threat Factor Score, Threat Factor Level, Occurrence, Incident Likelihood, Impact Level, Inherent Risk, Mitigated Risk, Residual Risk, Residual Risk Level, and Management Decision.

- ✓ The Risks CSV is the recommended format for importing into a risk register in Excel, Jira, or GRC platforms such as ServiceNow.

7.2 Vulnerability CSV Export

Produces a CSV with one row per Vulnerability. Columns include: Vulnerability ID, Name, Description, CVE Score, Severity Level, Tracking ID, Tracking URI, and the list of linked Supporting Assets.

7.3 Full Assessment JSON

Exports the complete assessment as a structured JSON document. This file contains all project metadata, business assets, supporting assets, vulnerabilities, risk scenarios, attack paths, and mitigations. The JSON schema is versioned and can be used for:

- Archiving completed assessments in a document management system.
- Importing into a future ISRA version or a custom reporting tool.
- Automated processing by security pipelines (e.g. CI/CD risk gates).

- ! The JSON export file is the authoritative record of an assessment. Store it in version control or a secure document repository after every assessment iteration.

8 TROUBLESHOOTING

Issue: Application fails to start

Symptom	The splash screen disappears immediately.
Resolution	Verify that the Spring Boot JAR exists at backend/target/. Re-run mvn clean package -DskipTests. Check backend.log for Java errors.

Issue: Blank white screen after splash

Symptom	Main window opens but no content loads.
Resolution	Confirm the Angular dev server is running on port 4200. Check electron.log for the "Backend ready" message. Ensure no firewall is blocking localhost traffic.

Issue: AI suggestions button is greyed out

Symptom	The "AI Suggest" button remains disabled.
Resolution	You must select at least one asset (Business Asset or Supporting Asset) before AI suggestions become available. Also verify the AI badge shows "AI Available" — if it shows "Not Configured", the API key is missing.

Issue: "Project not found" error

Symptom	Error appears when opening a project.
Resolution	The local H2 database file may be corrupted. Locate the database at ~/.config/SecurityRiskAssessmentTool/data/ and check backend.log for Hibernate errors.

Issue: Validation banner will not dismiss

Symptom	Red warning banner persists at the top of a form.
Resolution	All required fields (marked with *) must be filled in. Check for empty fields, especially hidden ones that may require scrolling.

Issue: Export produces empty CSV

Symptom	Downloaded CSV file has headers but no data rows.
Resolution	Ensure at least one risk scenario or vulnerability has been saved. Navigate away and back to the Report tab to refresh the data.

Issue: AI suggestions are irrelevant	
Symptom	Gemini returns generic or unrelated suggestions.
Resolution	Provide a more detailed Project Description in the Project Context step. The AI uses that description as context for its suggestions.

Log File Locations

ISRA writes diagnostic logs to the following paths:

- **electron.log** → ~/.config/SecurityRiskAssessmentTool/logs/electron.log
- **backend.log** → ~/.config/SecurityRiskAssessmentTool/logs/backend.log

Tail these files live while the application is running for real-time diagnostics:

```
tail -f ~/.config/SecurityRiskAssessmentTool/logs/backend.log
```

9 KEYBOARD SHORTCUTS & TIPS

Keyboard Shortcuts

Shortcut	Action
Ctrl + S / Cmd + S	Save current project state
Ctrl + O / Cmd + O	Open a project file (via system dialog)
Ctrl + N / Cmd + N	Create a new assessment
Ctrl + Q / Cmd + Q	Quit ISRA
Tab	Move focus to the next form field
Shift + Tab	Move focus to the previous form field
Escape	Close the currently open dialog or panel

Best Practice Tips

1	Start with a thorough Project Description	The Project Context description is used by the AI to generate relevant suggestions. The more detail you provide about the system architecture and threat environment, the better the suggestions will be.
2	Link every Supporting Asset to a Business Asset	Unlinked Supporting Assets cannot appear in Risk Scenario dropdowns. Always establish the asset relationship before moving to the Vulnerabilities step.
3	Use the Tracking ID field for every vulnerability	Always link vulnerabilities to your issue tracker (Jira, ServiceNow, etc.). This makes it possible to close ISRA findings when patches are deployed.
4	Define multiple Attack Paths per Risk Scenario	A single risk scenario can be reached via multiple vulnerability chains. Model all realistic attack paths to ensure the likelihood calculation reflects the full attack surface.
5	Export JSON after every completed iteration	Save the full JSON export to version control after each assessment iteration. This provides an audit trail and enables diff comparison between versions.
6	Use the "Reduce" decision, not just "Accept"	Risks marked "Accept" are excluded from the mitigation benefit calculation. Only use "Accept" when you have consciously decided no action is needed. Use "Reduce" for any risk you plan to treat, even partially.

7

Iterate the assessment

ISRA supports iterative assessments. Each time you open and update a project, the tracking history records the date and revision. Run at least one re-assessment after major design changes or new CVE disclosures.

For technical issues or feature requests, please raise a ticket in your organisation's issue tracker or contact your ISRA administrator.

ISRA User Guide · Version 1.0 · June 2026 · Thales Group